

RAPPORT D'ANALYSE FORENSIQUE

HASAN2

Autopsie d'une image disque Windows - investigation numérique

Paramètre	Valeur
Environnement	TryHackMe - Disk Analysis (laboratoire autorisé)
Preuve analysée	img_HASAN2.E01 - image disque E01
Outil principal	Autopsy 4.18.0
Date de l'analyse	18 juillet 2026
Enquêteur	Dimitri Marquet - dimisan221
Version	2.0 - harmonisation graphique et structurelle

CLASSIFICATION Ce rapport contient des informations techniques sensibles. Sa diffusion doit rester limitée aux personnes autorisées.

Rapport établi à partir des artefacts consignés dans l'image disque du laboratoire.

Contrôle du document

Historique des versions

Version	Date	Auteur	Description
1.0	18/07/2026	dimisan221	Rapport initial d'analyse forensique HASAN2.
2.0	28/08/2026	dimisan221	Reprise de la structure et de la présentation du rapport Beach Bar.

Destinataires

Destinataire principal : évaluateur pédagogique ou responsable d'investigation. Toute diffusion complémentaire doit être autorisée.

Avertissement

Cette investigation a été réalisée dans un cadre strictement éducatif sur une image fournie par TryHackMe. Les méthodes décrites ne doivent être appliquées qu'à des supports et systèmes dont l'analyse est explicitement autorisée.

PORTÉE DU RAPPORT Les conclusions reposent sur les artefacts documentés dans le rapport source. Aucune acquisition complémentaire, analyse mémoire ou validation sur le système vivant n'a été réalisée.

Table des matières

- 1. Synthèse exécutive**
- 2. Informations sur le dossier**
- 3. Preuve numérique et chaîne de possession**
- 4. Méthodologie d'investigation**
- 5. Résultats de l'analyse**
- 6. Chronologie synthétique**
- 7. Indicateurs de compromission**
- 8. Recommandations prioritaires**
- 9. Conclusion**

Annexe A. Artefacts et références

1. Synthèse exécutive

L'analyse post-mortem de l'image img_HASAN2.E01, issue d'un poste Windows 10, a identifié des traces cohérentes avec une activité malveillante interne. Le niveau de risque global est évalué comme élevé.

CONSTAT PRINCIPAL Des outils de récupération de mots de passe ont été téléchargés, un script d'élévation de privilèges a été retrouvé et un fichier de compromission a été déposé sur le bureau d'un autre utilisateur.

Vue d'ensemble des constats

ID	Constat	Sévérité	Effet principal
HF-01	Présence de LaZagne et Mimikatz	Élevée	Récupération potentielle d'identifiants
HF-02	Script exploit.ps1 avec contrôle Administrateurs	Élevée	Élévation de privilèges locale
HF-03	Dépôt de hacked.txt sur le bureau de H4S4N	Moyenne	Preuve d'accès intercompte
HF-04	Look@LAN installé	Faible	Surveillance réseau à qualifier

Impacts observés ou plausibles

- Confidentialité : exposition potentielle de mots de passe et d'informations utilisateurs.
- Intégrité : modification d'un fichier indicateur et dépôt d'un fichier sur le bureau d'un autre compte.
- Privilèges : éléments indiquant une exécution dans le groupe Administrateurs.
- Traçabilité : les artefacts permettent de reconstruire une partie de l'activité, mais pas d'attribuer formellement chaque action.

2. Informations sur le dossier

Élément	Valeur
Adresse IP de l'environnement	10.129.185.70
Compte fourni	administrator - mot de passe non reproduit
Outil d'investigation	Autopsy 4.18.0
Type d'image	E01 - EnCase Evidence File
Nom de la preuve	img_HASAN2.E01
Approche	Analyse post-mortem en lecture seule

BONNE PRATIQUE Le mot de passe du compte fourni n'est pas reproduit afin de limiter la diffusion d'identifiants.

3. Preuve numérique et chaîne de possession

L'intégrité logique de l'image a été contrôlée par empreinte MD5. Cette vérification permet de détecter une modification entre l'acquisition et l'analyse, sous réserve que la valeur de référence soit elle-même fiable et correctement conservée.

Propriété	Valeur
Nom	img_HASAN2.E01
Taille	65 433 829 376 octets - environ 61 Go
Taille de secteur	512 octets
Fuseau horaire	America/New_York
Device ID	bc9ef60d-bb21-4d94-a08f-3c169aa07774
Empreinte MD5	3f08c518adb3b5c1359849657a9b2079
Volume principal	vol3 - NTFS / exFAT

4. Méthodologie d'investigation

L'analyse a suivi une approche dead-box forensics, sans modification volontaire du support source.

1. Chargement de l'image E01 en lecture seule dans Autopsy.
2. Vérification de l'intégrité par calcul de l'empreinte MD5.
3. Extraction des ruches SYSTEM, SAM et SOFTWARE.
4. Analyse des bureaux, téléchargements, favoris Firefox et historique PowerShell.
5. Recherche de fichiers d'intérêt, d'outils offensifs et de règles YARA.
6. Reconstruction chronologique à partir des métadonnées MACB.

4.1 Limites

- Aucune analyse mémoire vive n'est documentée.
- Aucune corrélation avec des journaux réseau, EDR ou Active Directory n'est disponible.
- Les horodatages peuvent être affectés par le fuseau, l'horloge système ou une manipulation.
- La présence d'un outil ne prouve pas à elle seule son exécution ; elle doit être corrélée avec d'autres artefacts.

PRUDENCE D'INTERPRÉTATION Le rapport établit des constats techniques et une chronologie probable. Il ne constitue pas une expertise judiciaire opposable.

5. Résultats de l'analyse

5.1 Informations système

Élément	Valeur
Nom du poste	DESKTOP-6R59DJ3
Système	Windows NT - architecture AMD64
Adresse IP locale	192.168.130.216
Adresse MAC	08-00-27-2C-C4-B9
Carte réseau	Intel(R) PRO/1000 MT Desktop Adapter

5.2 Comptes utilisateurs

La ruche SAM contient les comptes locaux suivants, par ordre alphabétique :

- H4S4N, joshwa, keshav, sandhya, shreya, sivapriya, srini et suba.

DERNIÈRE CONNEXION OBSERVÉE Le dernier accès relevé dans la ruche SAM correspond au compte sivapriya.

5.3 Activité utilisateur

Un favori Google Maps a été retrouvé dans places.sqlite avec les coordonnées 12°52'23.0"N 80°13'25.0"E. Un fond d'écran personnalisé a également permis d'associer le compte joshwa au nom Anto Joshwa.

5.4 Logiciel de surveillance réseau

La ruche SOFTWARE indique l'installation de Look@LAN 2.90 Build 35. Sa légitimité doit être confirmée avec le propriétaire du poste et l'inventaire logiciel autorisé.

5.5 Artefact PowerShell - modification d'un indicateur

L'historique ConsoleHost_history.txt du compte shreya montre la lecture puis la modification manuelle d'un fichier texte présent sur le bureau.

```
Get-Content .\shreya.txt
Add-Content .\shreya.txt 'flag{HarleyQuinnForQueen}'
Get-Content .\shreya.txt
Set-Content .\shreya.txt 'flag{i_changed_it}'
exit
```

INTERPRÉTATION L'indicateur initial flag{HarleyQuinnForQueen} a été remplacé par flag{i_changed_it}. L'historique établit une modification depuis la session shreya.

5.6 Élévation de privilèges détectée

Le script exploit.ps1 vérifie l'appartenance au groupe Administrateurs via le SID S-1-5-32-544, puis crée un fichier hacked.txt sur le bureau de H4S4N.

```
if (groups -match 'S-1-5-32-544') {
    New-Item 'C:\Users\H4S4N\Desktop\hacked.txt'
    Add-Content ... 'flag{I-hacked-you}'
}
```

Le fichier déposé contient le message `flag{I-hacked-you}`. Ce dépôt constitue une preuve d'accès avec des droits permettant d'écrire dans le profil d'un autre utilisateur.

5.7 Outils offensifs identifiés

Deux outils connus de récupération de mots de passe ont été retrouvés dans les téléchargements du compte H4S4N :

- LaZagne ;
- Mimikatz, sous la forme `mimikatz_trunk.zip`.

Une règle YARA nommée `kiwi_passwords.yar` ciblait également Mimikatz. Les métadonnées attribuent cette règle à Benjamin Delpy, alias `gentilkiwi`.

QUALIFICATION La présence simultanée d'outils offensifs, d'un script d'élévation et d'un fichier déposé renforce l'hypothèse d'une activité volontairement malveillante. Une preuve d'exécution supplémentaire serait toutefois nécessaire pour attribuer chaque action avec certitude.

Éléments à corrélér

- Prefetch, Amcache, Shimcache et journaux PowerShell pour confirmer l'exécution.
- Journaux de sécurité Windows pour identifier les connexions et changements de privilèges.
- Historique navigateur et métadonnées de téléchargement pour l'origine des outils.
- Télémétrie EDR ou antivirus pour les détections et actions de remédiation.

6. Chronologie synthétique

Date / heure EST	Événement
2021-02-06 05:38:00	Création du compte <code>joshwa</code> , utilisé comme référence de comparaison.
2021-02-06 05:39:20 à 05:42:00	Création des comptes <code>keshav</code> , <code>sandhya</code> , <code>shreya</code> , <code>sivapriya</code> , <code>sriini</code> et <code>suba</code> .
2021-02-06 09:56:28	Téléchargement de LaZagne et Mimikatz par H4S4N.
2021-02-06 10:05:17 à 10:05:22	Présence de la règle YARA Mimikatz et de résultats de recherche.
2021-02-06 12:40:10 à 12:40:36	Modification de <code>shreya.txt</code> via PowerShell.
2021-02-07 12:05:37	Dernière connexion observée : <code>sivapriya</code> .

LECTURE DE LA CHRONOLOGIE Les événements montrent une concentration d'activité le 6 février 2021, suivie d'une dernière connexion le lendemain. Le fuseau de référence est `America/New_York`.

Séquence probable

1. Création et utilisation de plusieurs comptes locaux.
2. Téléchargement d'outils de récupération de secrets.
3. Présence d'éléments de détection YARA.
4. Modification d'un indicateur via PowerShell.
5. Élévation locale et dépôt d'une preuve sur un autre profil.

7. Indicateurs de compromission

Type	Valeur	Sévérité
Archive	mimikatz_trunk.zip	Élevée
Exécutable	LaZagne - récupération de mots de passe	Élevée
Script	exploit.ps1 - contrôle du SID Administrateurs	Élevée
Fichier déposé	C:\Users\H4S4N\Desktop\hacked.txt	Moyenne
Règle YARA	kiwi_passwords.yar	Information
Logiciel	Look@LAN 2.90 Build 35	Faible

8. Recommandations prioritaires

Priorité	Délai	Action	Résultat attendu
P0	Immédiat	Isoler le poste et préserver les preuves avant toute modification.	Conservation de l'intégrité de l'enquête.
P0	Immédiat	Révoquer les secrets susceptibles d'avoir été récupérés.	Réduction du risque de réutilisation.
P1	7 jours	Rechercher LaZagne, Mimikatz, exploit.ps1 et hacked.txt sur le parc.	Détection d'une propagation éventuelle.
P1	14 jours	Activer journalisation PowerShell, EDR et règles YARA contrôlées.	Amélioration de la détection.
P2	30 jours	Restreindre les téléchargements et droits administrateur locaux.	Réduction de la surface d'abus.

9. Conclusion

L'image img_HASAN2.E01 contient des éléments compatibles avec une activité malveillante interne : outils de récupération de mots de passe, script d'élévation de privilèges, modification d'un indicateur et dépôt d'un fichier sur le bureau d'un autre utilisateur.

Ces constats suggèrent un scénario de compromission locale plutôt qu'une attaque externe directement observable dans les preuves fournies. Ils doivent être corrélés avec les journaux Windows, la télémétrie EDR et les données réseau avant toute attribution définitive.

RISQUE RÉSIDUEL Le risque reste élevé tant que les secrets potentiellement exposés ne sont pas renouvelés et que l'étendue de la compromission n'a pas été recherchée sur les autres postes.

Annexe A - Artefacts et références

- Image analysée : img_HASAN2.E01 - empreinte MD5 3f08c518adb3b5c1359849657a9b2079.
- Ruches Windows : SYSTEM, SAM et SOFTWARE.
- Historique PowerShell : ConsoleHost_history.txt.
- Fichiers d'intérêt : exploit.ps1, hacked.txt, mimikatz_trunk.zip et kiwi_passwords.yar.
- Outil d'analyse : Autopsy 4.18.0.

PRÉCAUTION DE LECTURE Ce document est pédagogique et ne constitue pas un rapport d'expertise légale opposable.